User Story : Authentication and Authorization

As a system user, I want to securely log in with multi-factor authentication and access only features and data relevant to my specific role so that sensitive hospital information is protected according to HIPAA regulations and I can work efficiently with appropriate system permissions .

Acceptance Criteria

Acceptance Criterion 1: Role-Based Access Control

- Given I am a user with a "Doctor" role logged into the system
- When I attempt to access the "Patient Records" module and the "Staff Payroll" module
- Then the system grants me full access to "Patient Records" with read/write permissions AND denies access to "Staff Payroll" displaying an "Access Denied - Insufficient Permissions" message

Acceptance Criterion 2: Secure Multi-Factor Authentication

- Given I am attempting to log into the hospital system
- When I enter my username and password correctly
- Then the system requires secondary authentication (SMS code, authenticator app, or biometric verification) before granting system access

Acceptance Criterion 3: Session Management and Security

- Given I am successfully logged into the system
- When I remain inactive for 30 minutes or attempt to access the system from multiple devices simultaneously
- Then the system automatically logs me out for security, requires re-authentication for concurrent sessions, and logs all access attempts for audit purposes

Acceptance Criterion 4: Granular Permission Management

- Given I have a specific role with defined permissions (Doctor, Nurse, Administrator, Receptionist)
- When I navigate through different system modules
- Then the system displays only menu items and features I have permission to access, hides unauthorized functions, and shows role-appropriate dashboards

Acceptance Criterion 5: Patient Data Access Restrictions

- Given I am a healthcare provider accessing patient records
- When I attempt to view patient information

- Then the system allows access only to patients under my direct care, logs all patient record access for HIPAA compliance, and requires additional authorization for emergency access to other patients

Acceptance Criterion 6: Password Security and Management

- Given I need to maintain secure system access
- When I create or update my password
- Then the system enforces strong password requirements (minimum 12 characters, special characters, numbers), requires password changes every 90 days, and prevents reuse of last 12 passwords

Acceptance Criterion 7: Failed Login Attempt Protection

- Given someone is attempting to access my account
- When there are 3 consecutive failed login attempts
- Then the system temporarily locks the account for 15 minutes, sends security alerts to the user and administrators, and requires additional verification for account unlock

Acceptance Criterion 8: Audit Trail and Compliance Logging

- Given I am performing any system activities
- When I access, modify, or view any data in the system
- Then the system automatically logs all actions with timestamps, user identification, IP addresses, and data accessed for comprehensive audit trails and regulatory compliance